WHOAMI LABS

Entorno de laboratorio autorizado

INFORME DE PENTESTING

Evaluación de seguridad de la máquina

«Rascacielos»

Objetivo (IP)	172.17.0.2
Plataforma	WhoAmI Labs — laboratorio de prácticas
Dificultad declarada	Fácil (★★☆☆☆)
Fecha de la prueba	16 de octubre de 2026
Ventana de ejecución	11:37 – 13:47 (CEST) · 2 h 10 m
Tipo de prueba	Caja negra (black-box), no autenticada
Resultado	Compromiso total del sistema (acceso root)
Clasificación	CONFIDENCIAL

Documento generado con fines educativos y de documentación de prácticas (portfolio de writeups).

Aviso legal, alcance y autorización

Todas las pruebas descritas en este informe se han realizado **exclusivamente** dentro de un entorno de laboratorio aislado y explícitamente autorizado para el ataque (**WhoAmI Labs**). La máquina objetivo, con dirección IP `172.17.0.2`, es un sistema desechable desplegado por la propia plataforma para prácticas de pentesting.

Ninguna de las técnicas aquí documentadas debe aplicarse contra sistemas de terceros sin **autorización previa y por escrito**. La frontera entre un profesional de seguridad y un delito no es el conocimiento técnico, sino la autorización y el respeto estricto del alcance (scope).

Reglas de enfrentamiento (RoE) aplicadas

- **Alcance autorizado:** un único host, 172.17.0.2, en la red aislada del laboratorio.
- **Fuera de alcance:** cualquier otra dirección, la red doméstica del operador e Internet.
- **Técnicas permitidas:** enumeración, explotación web, acceso remoto y escalada de privilegios.
- **Objetivo del ejercicio:** obtener la flag del sistema y demostrar el impacto (acceso a nivel root).

Índice

(En Word: clic derecho sobre el índice → «Actualizar campos» para numerar las páginas.)

1. Resumen ejecutivo

Se realizó una prueba de intrusión de caja negra sobre el servidor `172.17.0.2`. El objetivo se comprometió por completo: partiendo de **cero credenciales y sin ningún acceso previo**, se consiguió ejecución de comandos como **root** (administrador total del sistema) en algo más de dos horas.

La causa raíz no fue una vulnerabilidad sofisticada, sino una **acumulación de malas prácticas de configuración**: un fichero de copia de seguridad con credenciales accesible desde la web, reutilización de esa misma contraseña para el acceso SSH, una inclusión de ficheros locales (LFI) en la aplicación, y un permiso `sudo` mal concedido que permitió saltar directamente a root. Cada fallo por separado es grave; encadenados, suponen el control absoluto de la máquina.

Mapa de riesgo (resumen para dirección)

Hallazgo	Severidad	Resumen
F-01	CRÍTICA	Fichero de respaldo (.config.bak) con credenciales de BD y del sistema accesible públicamente.
F-02	ALTA	Inclusión de ficheros locales (LFI) en index.php: lectura de ficheros arbitrarios del servidor.
F-03	ALTA	Credenciales débiles y reutilizadas (Sky2026!) para base de datos y acceso SSH.
F-04	CRÍTICA	Escalada de privilegios a root mediante sudo sobre /usr/bin/find sin contraseña.
F-05	MEDIA	Divulgación de información: versiones de servicios y ficheros sensibles descubiertos por fuerza bruta de rutas.

Recuento: 2 críticas · 2 altas · 1 media. Riesgo global del activo: **CRÍTICO**.

2. Alcance y metodología

2.1. Objetivo y entorno

Host objetivo	172.17.0.2 (contenedor / VM del laboratorio)
Sistema operativo	Ubuntu 20.04.6 LTS (identificado durante la prueba)
Superficie expuesta	SSH (22/tcp) y HTTP (80/tcp)
Máquina atacante	Kali Linux (misma red aislada)
Perspectiva	Atacante externo sin credenciales (black-box)

2.2. Metodología

El trabajo siguió las fases clásicas de una operación de intrusión, alineadas con marcos reconocidos del sector (PTES / OWASP) y con las tácticas de MITRE ATT&CK:

1. **Reconocimiento y enumeración** — descubrimiento de servicios y rutas.
2. **Análisis de vulnerabilidades** — identificación de puntos débiles (LFI, ficheros expuestos).
3. **Explotación / acceso inicial** — obtención de una sesión interactiva en el sistema.
4. **Escalada de privilegios** — de usuario sin privilegios a root.
5. **Post-explotación y evidencia** — captura de la flag como prueba de compromiso.

2.3. Herramientas utilizadas

Herramienta	Uso en esta prueba
`Nmap`	Descubrimiento de hosts, puertos y versiones de servicio.
`feroxbuster`	Enumeración recursiva de rutas y ficheros del servidor web.
`gobuster`	Enumeración de directorios/ficheros (descubre .config.bak).
`curl`	Recuperación directa de ficheros y prueba del LFI.
`Navegador web`	Explotación visual del LFI (index.php?page=).
`Cliente SSH`	Acceso inicial y escalada de privilegios.

3. Narrativa técnica del ataque

Esta sección reconstruye la cadena de ataque paso a paso, con las evidencias capturadas durante la ejecución.

3.1. Reconocimiento y enumeración de servicios

Se lanzó un escaneo completo de puertos TCP con detección de versiones y scripts por defecto sobre el objetivo:

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo revela únicamente dos servicios expuestos, ambos en versiones de Ubuntu identificables:

- **22/tcp — SSH**: OpenSSH 8.2p1 (Ubuntu). Vía de acceso remoto.
- **80/tcp — HTTP**: Apache httpd 2.4.41 (Ubuntu), sirviendo la página por defecto de Apache2.

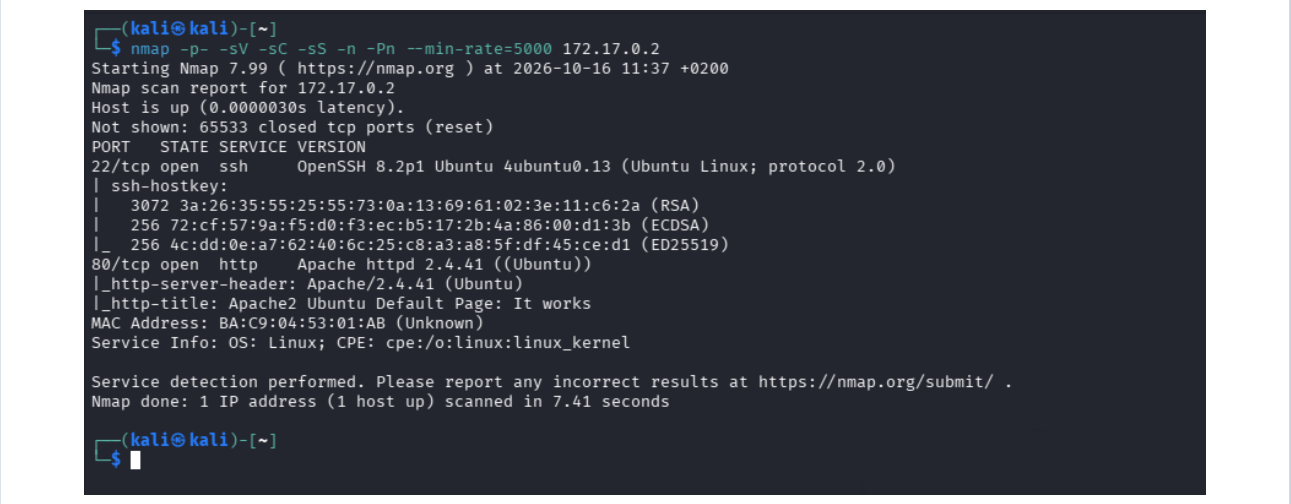


Figura 1 — Resultado del escaneo Nmap: puertos 22 (SSH) y 80 (HTTP) abiertos.

3.2. Enumeración del servidor web

Dado que el puerto 80 mostraba la página por defecto, se enumeraron rutas y ficheros ocultos. Primero con `feroxbuster`, que descubre una aplicación PHP real tras la página por defecto (index.php, about.php, contact.php, home.php y componentes header/footer):

```
feroxbuster -u http://172.17.0.2/ -t 10 \
  -x php,txt,html,py,zip \
  -w .../seclists/Discovery/Web-Content/raft-medium-directories.txt
```



Figura 2 — feroxbuster revela la aplicación PHP oculta tras la página por defecto de Apache.

Una segunda pasada con `gobuster` incluyendo la extensión `.bak` destapa el hallazgo clave: un fichero de respaldo **`.config.bak`** accesible con código `200 OK`:

```
gobuster dir -u http://172.17.0.2 \
  -w /usr/share/wordlists/dirb/common.txt \
  -x py,txt,bak,html,php -t 50
```

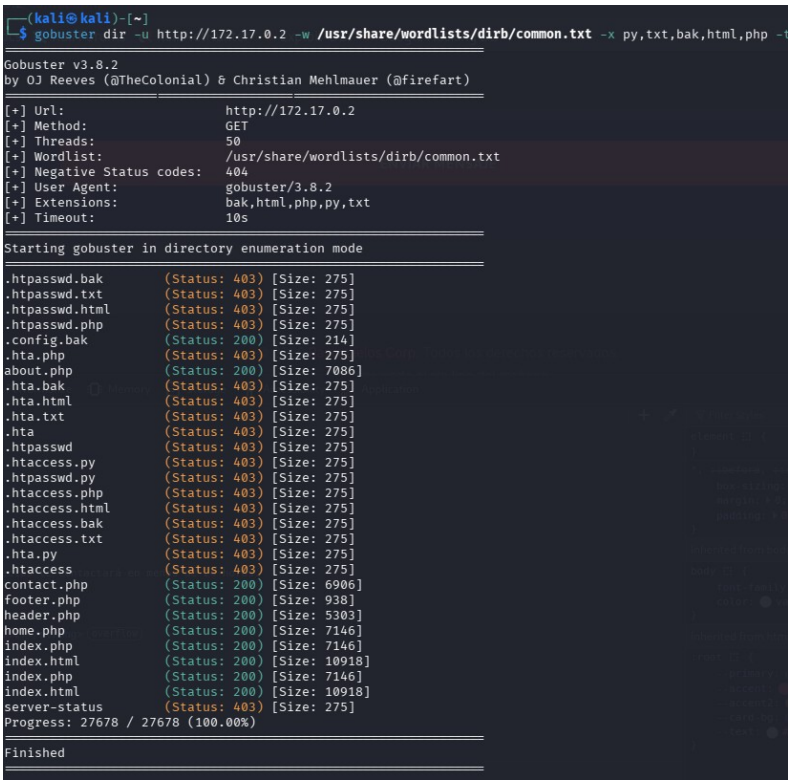


Figura 3 — gobuster descubre «.config.bak» (200 OK), un fichero de respaldo que no debería ser público.

3.3. Exposición de credenciales en el fichero de respaldo

Al solicitar el fichero de respaldo se obtiene, en texto plano, la configuración de la aplicación, incluyendo las credenciales de la base de datos y una contraseña del «sistema interno»:

```
curl -s http://172.17.0.2/.config.bak
```

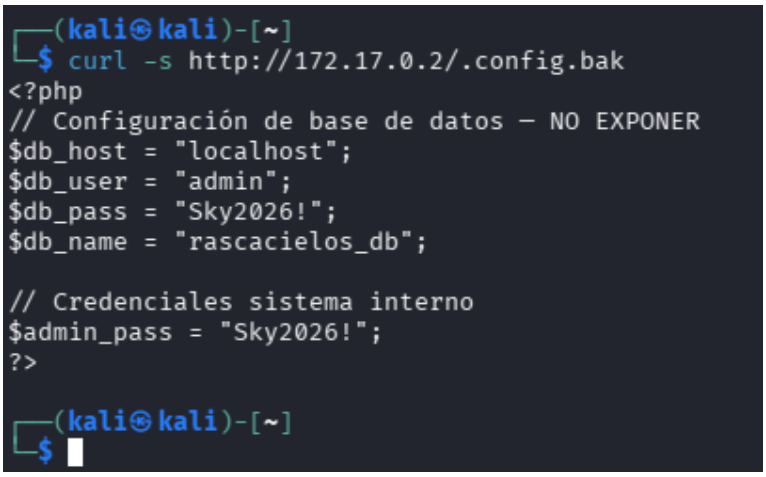


Figura 4 — El fichero .config.bak expone las credenciales en claro (usuario admin / contraseña Sky2026!).

Credenciales obtenidas: usuario **`admin`** y contraseña **`Sky2026!`**, reutilizada además como `$admin_pass`. La ironía del comentario «NO EXPONER» en un fichero servido públicamente resume el problema.

3.4. Inclusión de ficheros locales (LFI)

La aplicación carga sus secciones mediante un parámetro `page` (p. ej. `index.php?page=home.php`). Al sustituir el valor por una ruta del sistema, el servidor incluye y muestra el fichero solicitado, confirmando una vulnerabilidad de **Local File Inclusion**:

```
http://172.17.0.2/index.php?page=/etc/passwd
```

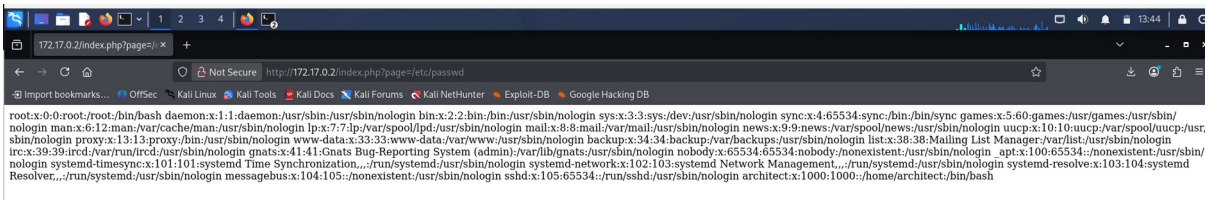


Figura 5 — El LFI permite leer /etc/passwd. Se identifica el usuario «architect» (UID 1000, shell /bin/bash).

La lectura de `/etc/passwd` revela un usuario local con shell interactiva: **`architect`** (UID 1000). Esto proporciona un nombre de usuario válido para intentar autenticación remota.

3.5. Acceso inicial por SSH

Combinando las dos piezas anteriores — el usuario `architect` (del LFI) y la contraseña `Sky2026!` (del fichero de respaldo) — se consigue una sesión SSH válida. Se trata de un caso claro de **reutilización de credenciales**:

```
ssh architect@172.17.0.2
# contraseña: Sky2026!
```

Ya dentro del sistema, el primer paso de la escalada es revisar los permisos `sudo` del usuario con `sudo -l`. El resultado es demoledor:

```
architect@rascacielos:~$ sudo -l
User architect may run the following commands on rascacielos:
    (ALL) NOPASSWD: /usr/bin/find
```

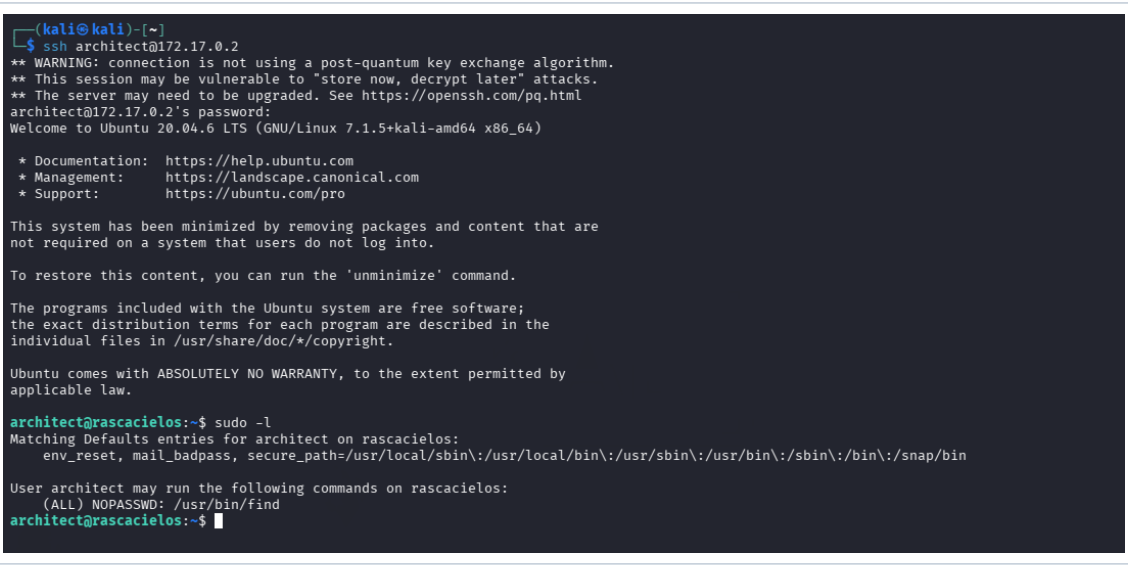


Figura 6 — Acceso SSH como «architect» y salida de «sudo -l»: puede ejecutar /usr/bin/find como root sin contraseña.

3.6. Escalada a root y captura de la flag

El permiso para ejecutar `find` como root es un vector de escalada documentado (GTFOBins). La opción `-exec` de `find` permite lanzar un intérprete de comandos que hereda los privilegios de root:

```
sudo find . -exec /bin/bash \; -quit
id
# uid=0(root) gid=0(root) groups=0(root)
cat /root/flag.txt
```

El comando abre una shell con **`uid=0(root)`**. A partir de aquí el control del sistema es total. Se lee la flag como prueba de compromiso:

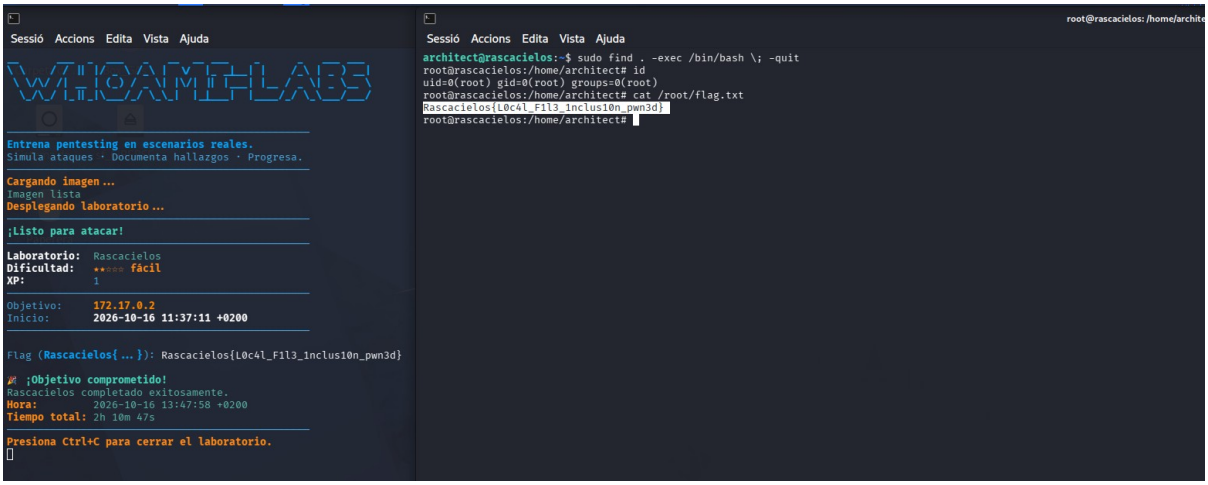


Figura 7 — Shell como root (uid=0) y captura de la flag: Rascacielos{L0c4l_F1l3_1nclus10n_pwn3d}. Objetivo comprometido.

FLAG CAPTURADA `Rascacielos{L0c4l_F1l3_1nclus10n_pwn3d}`

4. Hallazgos detallados

Cada hallazgo incluye su severidad, una puntuación CVSS 3.1 orientativa, el impacto y la remediación recomendada.

F-01 Fichero de respaldo con credenciales expuesto públicamente

Severidad	CRÍTICA	CVSS 3.1: 9.1	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H

Descripción

El fichero `.config.bak` está accesible sin autenticación en la raíz web y devuelve, en texto plano, las credenciales de la base de datos y de un «sistema interno» (**`admin / Sky2026!`**). Los ficheros de respaldo (.bak, .old, ~) suelen quedar fuera del procesado de PHP y se sirven como texto.

Impacto

Un atacante anónimo obtiene credenciales válidas que, como se demostró, dan acceso al sistema y a la base de datos. Es el primer eslabón de toda la cadena de compromiso.

Evidencia: *Figura 4.*

Remediación

- Eliminar de inmediato el fichero .config.bak del servidor web.
- Nunca guardar copias de seguridad dentro de la raíz pública; usar un directorio fuera del DocumentRoot.
- Bloquear el acceso a extensiones sensibles en Apache (p. ej. `<FilesMatch "\.(bak|old|swp|config)$"> Require all denied`).
- Rotar todas las credenciales que hayan podido quedar expuestas.

F-02 Inclusión de ficheros locales (LFI) en index.php

Severidad	ALTA	CVSS 3.1: 7.5	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N

Descripción

El parámetro `page` de `index.php` se incluye sin validación, permitiendo leer ficheros arbitrarios del servidor (`index.php?page=/etc/passwd`). Según la configuración de PHP, un LFI puede evolucionar hacia ejecución remota de código (log poisoning, wrappers php://, session poisoning).

Impacto

Lectura de ficheros sensibles (configuración, código fuente, claves, /etc/passwd). En este caso permitió enumerar usuarios locales válidos y preparar el acceso SSH.

Evidencia: *Figura 5.*

Remediación

- No construir rutas de inclusión a partir de entrada del usuario.
- Usar una lista blanca de páginas permitidas (un switch/mapa fijo de valores válidos).
- Sanear la entrada (rechazar `../`, rutas absolutas y wrappers) y desactivar `allow_url_include`.

F-03 Credenciales débiles y reutilizadas

Severidad	ALTA	CVSS 3.1: 8.1	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H

Descripción

La misma contraseña (**`Sky2026!`**) se reutiliza para la base de datos, un «admin» interno y la cuenta SSH del usuario `architect`. Además sigue un patrón predecible (palabra + año + símbolo).

Impacto

La reutilización convierte una única fuga (F-01) en acceso interactivo al sistema. Una contraseña comprometida abre todas las puertas a la vez.

Evidencia: *Figuras 4 y 6.*

Remediación

- Usar contraseñas únicas, largas y aleatorias por servicio, gestionadas con un gestor de contraseñas.
- Prohibir la reutilización entre sistemas y aplicar una política de complejidad y rotación.
- Habilitar autenticación por clave pública (y/o MFA) en SSH y deshabilitar la autenticación por contraseña.

F-04 Escalada de privilegios a root vía sudo sobre find

Severidad	CRÍTICA	CVSS 3.1: 8.8	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Descripción

El usuario `architect` puede ejecutar `/usr/bin/find` como root sin contraseña (`NOPASSWD`). La opción `-exec` de find permite lanzar `/bin/bash` con privilegios de root (técnica estándar de GTFOBins).

Impacto

Compromiso total del host: control a nivel root, acceso a todos los datos, persistencia y pivoting. Convierte un acceso limitado en administración completa de la máquina.

Evidencia: *Figuras 6 y 7.*

Remediación

- Retirar el permiso sudo sobre find (y sobre cualquier binario con capacidad de -exec/shell).
- Aplicar el principio de mínimo privilegio: conceder solo comandos concretos y no interactivos, evitando NOPASSWD.
- Si se necesita find con sudo, restringir argumentos mediante scripts envoltorio validados y auditados.

F-05 Divulgación de información (versiones y rutas sensibles)

Severidad	MEDIA	CVSS 3.1: 5.3	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N

Descripción

Los servicios exponen versiones exactas (OpenSSH 8.2p1, Apache 2.4.41, Ubuntu) y la estructura de la aplicación es enumerable por fuerza bruta de rutas, incluyendo ficheros que deberían estar ocultos.

Impacto

Facilita al atacante identificar vulnerabilidades conocidas y localizar ficheros sensibles, acelerando el resto de la cadena.

Evidencia: *Figuras 1, 2 y 3.*

Remediación

- Minimizar banners: `ServerTokens Prod` y `ServerSignature Off` en Apache.
- Eliminar ficheros y páginas por defecto y de respaldo; mantener solo lo necesario en producción.
- Mantener los servicios actualizados y monitorizar los escaneos de enumeración.

---

5. Cadena de ataque (resumen)

Los hallazgos no son independientes: se encadenan. Esta es la secuencia que llevó del anonimato total a root:

Paso	Acción	Hallazgo
1. Recon	Nmap descubre SSH (22) y HTTP (80).	**F-05**
2. Enumeración web	feroxbuster/gobuster destapan la app PHP y el fichero .config.bak.	**F-05**
3. Fuga de credenciales	.config.bak revela admin / Sky2026!.	**F-01**
4. LFI	index.php?page=/etc/passwd identifica al usuario «architect».	**F-02**
5. Acceso inicial	SSH con architect / Sky2026! (credencial reutilizada).	**F-03**
6. Escalada	sudo find -exec /bin/bash → shell root (uid=0).	**F-04**
7. Objetivo	Lectura de /root/flag.txt. Compromiso total.	—

6. Recomendaciones priorizadas

Inmediatas (horas)

- Eliminar `.config.bak` y cualquier otro respaldo del servidor web (F-01).
- Rotar la contraseña `Sky2026!` en todos los servicios donde se use (F-03).
- Retirar el permiso `sudo NOPASSWD sobre /usr/bin/find` (F-04).

Corto plazo (días)

- Corregir el LFI con lista blanca de páginas y saneado de entrada (F-02).
- Imponer autenticación SSH por clave y deshabilitar el login por contraseña (F-03).
- Reducir banners de versión y limpiar ficheros por defecto (F-05).

Estructurales (proceso)

- Revisión de permisos sudo de todas las cuentas bajo el principio de mínimo privilegio.
- Política de contraseñas únicas por servicio y gestor de secretos; prohibir credenciales en el código.
- Revisión de seguridad previa al despliegue (no publicar backups, ficheros ocultos ni código fuente).

7. Conclusión

La máquina «Rascacielos» se comprometió por completo en poco más de dos horas sin explotar ninguna vulnerabilidad de día cero: **bastó con encadenar errores de configuración y de higiene de credenciales**. El patrón es representativo de entornos reales, donde el compromiso rara vez viene de un único fallo espectacular, sino de la suma de pequeñas negligencias.

Corregir los dos hallazgos críticos (F-01 y F-04) y la reutilización de credenciales (F-03) **rompe la cadena por completo** y degrada drásticamente el riesgo del activo. La lección principal para defensa: no publicar nunca respaldos, no reutilizar contraseñas y auditar con lupa los permisos `sudo`.

— Fin del informe —